Gestão da Privacidade dos Dados Pessoais

Pós-graduação em Compliance de Cibersegurança

linkedin.com/in/anderson-oliveira-da-silva-58221680

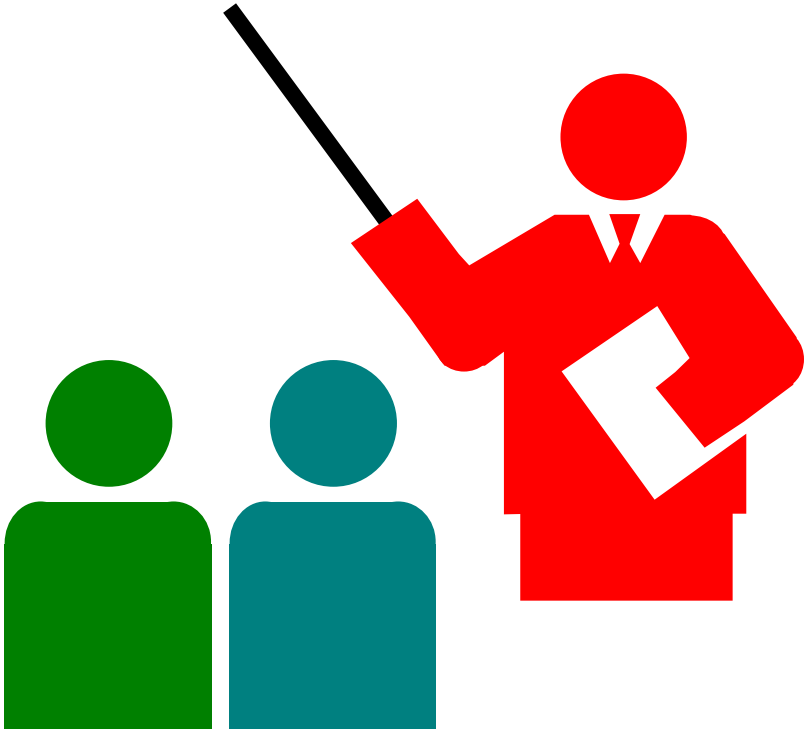
Prof. Anderson Oliveira da Silva

Gestor de Segurança da Informação
Encarregado de Dados Pessoais
anderson@inf.puc-rio.br

DEPARTAMENTO DE INFORMÁTICA PUC·RIO

PUC RIO

Proteção à Privacidade e aos Dados Pessoais – Conformidade com as Normas ISO e ABNT



Proteção à Privacidade e aos Dados Pessoais

Por que é tão importante para os titulares?

- **A exposição indevida de dados pessoais coloca pessoas em situação de vulnerabilidade e pode gerar consequências graves, como:**
  - **Prejuízos financeiros, como fraudes, golpes e extorsão.**
  - **Danos psicossociais, como constrangimento, estigmatização e discriminação.**
  - **Riscos físicos, como perseguição, ameaça e sequestro.**

Proteção à Privacidade e aos Dados Pessoais

Por que é tão importante para a organização?

- **A proteção da privacidade dos titulares de dados pessoais é um dos pilares centrais da segurança e da governança da informação.**

- **Não é apenas uma exigência legal – é um fator estratégico que afeta diretamente a confiança, a reputação, a continuidade de negócios e a responsabilidade organizacional.**

Proteção à Privacidade e aos Dados Pessoais

Por que é tão importante para a organização?

- **Organizações que tratam dados pessoais com cuidado demonstram respeito aos titulares.**

- **Essa confiança dos titulares:**
  - **Fortalece a relação com clientes, colaboradores e parceiros;**
  - **Torna a organização mais competitiva no mercado; e**
  - **Evita perda de clientes por causa de incidentes de privacidade.**

Proteção à Privacidade e aos Dados Pessoais

Como a organização pode assegurar a proteção da privacidade?

- **Para assegurar a privacidade dos dados pessoais e estar em conformidade com a LGPD, a organização deve adotar uma abordagem estruturada que envolve medidas técnicas, administrativas e de formação cultural.**

Proteção à Privacidade e aos Dados Pessoais

Como a organização pode assegurar a proteção da privacidade?

- **Para assegurar a privacidade dos dados pessoais e estar em conformidade com a LGPD, a organização deve adotar uma abordagem estrutu[illegible]cas, administrativas e [illegible]**

Compliance

Compliance é o ato de estar em conformidade com leis, regulamentos, normas e padrões éticos, tanto internos quanto externos, de uma organização.

Compliance

Compliance é o ato de estar em conformidade com leis, regulamentos, normas e padrões éticos, tanto internos quanto externos, de uma organização.

- Segurança da Informação, Segurança Cibernética e Proteção à Privacidade e aos Dados Pessoais
  - LGDP e Marco Civil da Internet
  - Família ISO 27000
  - ISO 29100 e ISO 29134
  - ISO 22301 e ISO 22313
  - Série NIST SP-800

Compliance

Compliance é o ato de estar em conformidade com leis, regulamentos, normas e padrões éticos, tanto internos quanto externos, de uma organização.

- **Segurança da Informação, Segurança Cibernética e Proteção à Privacidade e aos Dados Pessoais**
  - **LGPD e Resoluções da ANPD**
  - **ABNT NBR ISO/IEC 29100**
  - **ABNT NBR ISO/IEC 29134**
  - **ABNT NBR ISO/IEC 27701**

Pontos-chaves

Ativos de informação estão sujeitos a ameaças de perda, roubo ou danos.

- **A segurança da informação visa garantir a proteção dos ativos através da seleção e aplicação de salvaguardas apropriadas e alinhadas com o objetivo do negócio e a missão da organização.**

- **A cibersegurança visa garantir a proteção dos ativos contra as ameaças cibernéticas mantendo um nível aceitável de estabilidade, continuidade e segurança.**

Pontos-chaves

Informações de identificação pessoal (dados pessoais) devem ser protegidos para assegurar a proteção da privacidade das pessoas.

- **Pode-se ter segurança sem privacidade, mas não se pode ter privacidade sem segurança.**
- **Dados bem protegidos podem ser tratados de forma abusiva.**
- **O tratamento de dados de forma lícita não é suficiente para evitar vazamentos ou adulterações.**

Pontos-chaves

Informações de identificação pessoal (dados pessoais) devem ser protegidos para assegurar a proteção da privacidade das pessoas.

- **A proteção da privacidade visa garantir a conformidade da organização com os direitos fundamentais de privacidade dos titulares de dados pessoais (DP), conforme estabelecido pela Lei Geral de Proteção de Dados Pessoais (LGPD).**

- **A violação da privacidade é a situação onde os dados pessoais são tratados em violação de um ou mais requisitos pertinentes de salvaguarda da privacidade.**

ABNT NBR ISO/IEC 29100:2024 – Estrutura de Privacidade

O objetivo é aprimorar as normas de segurança no que tange tratamento de dados pessoais (DP).

- **Estabelece um framework internacional para proteção de privacidade e governança de dados pessoais.**

- **Fornece os princípios e os métodos para a proteção da privacidade em sistemas de Tecnologia da Informação (TI) e não se aprofunda nos detalhes operacionais.**

- **Fornece um arcabouço de princípios para a gestão da privacidade, enquanto a LGPD estabelece os direitos dos titulares e as obrigações dos controladores e operadores no tratamento dessas informações.**

ABNT NBR ISO/IEC 29100:2024 – Estrutura de Privacidade

A norma é organizada em quatro partes principais:

- **Terminologia comum de privacidade;**
- **Atores e papéis no tratamento de dados pessoais;**
- **Salvaguarda de privacidade; e**
- **Princípios de privacidade.**

ABNT NBR ISO/IEC 29100:2024 – Terminologia

A norma é organizada em quatro partes principais:

- **Anonimização**
  - **Processo pelo qual os dados pessoais são irreversivelmente alterados, de tal modo que um titular de DP não mais possa ser identificado, direta ou indiretamente, seja por um controlador de DP individualmente ou em colaboração com qualquer outra parte.**

LGPD, Art. 12. Os dados anonimizados não serão considerados dados pessoais para os fins desta Lei, salvo quando o processo de anonimização ao qual foram submetidos for revertido, utilizando exclusivamente meios próprios, ou quando, com esforços razoáveis, puder ser revertido.

- **Pseudonimização**
  - **Processo aplicado aos dados pessoais que substitui informação identificável por um pseudônimo.**

ABNT NBR ISO/IEC 29100:2024 – Terminologia

A norma é organizada em quatro partes principais:

- ## Anonimização (Exemplos)

Paciente	CEP	Idade	Médico	Medicamento
Paulo	22775	66	Pedro	Tramol
Sônia	22775	24	Sara	Novalgina
Ana Lucia	22451	43	Robson	Novalgina
Simone	22451	32	Pedro	Flanax
Silvio	22654	26	Gustavo	Tramol
Luiz	22775	38	Sara	Flanax
José	22451	41	Sayão	Novalgina

supressão de atributos

CEP	Idade	Médico	Medicamento
22775	66	Pedro	Tramol
22775	24	Sara	Novalgina
23451	43	Robson	Novalgina
23451	32	Pedro	Flanax
22654	26	Gustavo	Tramol
22775	38	Sara	Flanax
23451	41	Sayão	Novalgina

CEP	Idade	Médico	Medicamento
22775	66	Pedro	Tramol
22775	24	Sara	Novalgina
23451	43	Robson	Novalgina
23451	32	Pedro	Flanax
22654	26	Gustavo	Tramol
22775	38	Sara	Flanax
23451	41	Sayão	Novalgina

encobrimento de caracteres

CEP	Idade	Médico	Medicamento
22XXX	66	Pedro	Tramol
22XXX	24	Sara	Novalgina
23XXX	43	Robson	Novalgina
23XXX	32	Pedro	Flanax
22XXX	26	Gustavo	Tramol
22XXX	38	Sara	Flanax
23XXX	41	Sayão	Novalgina

ABNT NBR ISO/IEC 29100:2024 – Terminologia

A norma é organizada em quatro partes principais:

- **Pseudonimização (Exemplo)**

Paciente	CEP	Idade	Médico	Medicamento
Paulo	22775	66	Pedro	Tramol
Sônia	22775	24	Sara	Novalgina
Ana Lucia	22451	43	Robson	Novalgina
Simone	22451	32	Pedro	Flanax
Silvio	22654	26	Gustavo	Tramol
Luiz	22775	38	Sara	Flanax
José	22451	41	Sayão	Novalgina

substituição por pseudônimos

Paciente	CEP	Idade	Médico	Medicamento
A0X1Z3D4	22775	66	Pedro	Tramol
A1P0Q0D1	22775	24	Sara	Novalgina
Y0B4C8T0	22451	43	Robson	Novalgina
U0B1G0D2	22451	32	Pedro	Flanax
P3Q0R1S5	22654	26	Gustavo	Tramol
H2K5E3F8	22775	38	Sara	Flanax
L0G3Q1M4	22451	41	Sayão	Novalgina

Pseudônimo	Paciente
A0X1Z3D4	Paulo
A1P0Q0D1	Sônia
Y0B4C8T0	Ana Lucia
U0B1G0D2	Simone
P3Q0R1S5	Silvio
H2K5E3F8	Luiz
L0G3Q1M4	José

A tabela de associação entre os pseudônimos irreversíveis e os dados originais é mantida de forma segura no controlador e não é compartilhada.

ABNT NBR ISO/IEC 29100:2024 – Atores e Papéis

A norma define 4 atores, seus respectivos papéis e os fluxos de dados pessoais entre eles.

- **Titular de DP**
  - **Fornecem seus dados para os controladores e operadores de DP e, quando não previsto pela legislação aplicável, dão consentimento e determinam suas preferências de privacidade sobre como seus dados devem ser tratados.**
  - **Exemplos:**
    - **funcionários em sistemas de recursos humanos;**
    - **consumidores em relatórios de crédito;**
    - **pacientes em prontuários de saúde.**

ABNT NBR ISO/IEC 29100:2024 – Atores e Papéis

A norma define 4 atores, seus respectivos papéis e os fluxos de dados pessoais entre eles.

- **Controlador de DP**
  - **Determina os propósitos e os meios para o tratamento de DP, ou seja, decide por que e como os dados serão tratados.**
  - **Deve garantir que o tratamento de DP esteja em conformidade com os princípios de privacidade estabelecidos na norma.**
  - **Deve implementar os controles de privacidade para assegurar que as operações de tratamento sejam realizadas de maneira que respeitem os direitos dos titulares de DP.**
  - **Pode delegar a execução de algumas operações de tratamento a operadores de DP, mas a responsabilidade pelo tratamento permanece sendo sua.**

ABNT NBR ISO/IEC 29100:2024 – Atores e Papéis

A norma define 4 atores, seus respectivos papéis e os fluxos de dados pessoais entre eles.

- **Operador de DP**
  - **Realiza o tratamento de DP em nome do controlador de DP de acordo com as instruções do controlador.**
  - **Deve observar os requisitos de privacidade estabelecidos e implementar os controles de privacidade correspondentes.**
  - **Pode ser vinculado por um contrato que define suas obrigações e responsabilidades em relação ao tratamento dos dados.**
  - **Tipicamente, um operador de DP executa o processamento de dados, armazenamento e análise, sempre seguindo as diretrizes e instruções do controlador.**

ABNT NBR ISO/IEC 29100:2024 – Atores e Papéis

A norma define 4 atores, seus respectivos papéis e os fluxos de dados pessoais entre eles.

- **Terceira Parte**
  - **Parte interessada na privacidade que não é o titular de dados pessoais (DP), o controlador de DP ou o operador de DP.**
  - **Quando recebe dados pessoais, não trata esses dados em nome do controlador de DP.**
  - **Em geral, se torna um controlador de DP por direito próprio assim que recebe os dados em questão.**
  - **Exemplo de cenário:**
    - **Quando um controlador de DP fornece dados a uma terceira parte para fins comerciais ou por ordem de uma autoridade.**

ABNT NBR ISO/IEC 29100:2024 – Atores e Papéis vs Fluxo de DP

A norma define 4 atores, seus respectivos papéis e os fluxos de dados pessoais entre eles.

Cenários	Titular de DP	Controlador de DP	Operador de DP	Terceira Parte
1	Fornecedor de DP	Recebedor de DP		
2		Fornecedor de DP	Recebedor de DP	
3	Fornecedor de DP		Recebedor de DP	
4	Recebedor de DP	Fornecedor de DP		
5	Recebedor de DP		Fornecedor de DP	
6		Recebedor de DP	Fornecedor de DP	
7		Fornecedor de DP		Recebedor de DP
8			Fornecedor de DP	Recebedor de DP

ABNT NBR ISO/IEC 29100:2024 – Identificadores de DP

Os identificadores de são elementos que podem ser usados para identificar uma pessoa natural.

- **Identificadores Comuns (identificadores diretos)**
  - **As informações podem ser consideradas DP quando contêm ou estão associadas a um identificador que se refere a uma pessoa, como:**
    - **Número do Cadastro de Pessoa Física (CPF);**
    - **Número de passaporte;**
    - **Conta bancária;**
    - **Localização geográfica precisa;**
    - **Número de telefone.**

ABNT NBR ISO/IEC 29100:2024 – Identificadores de DP

Os identificadores de são elementos que podem ser usados para identificar uma pessoa natural.

- **Características Distintivas (identificadores indiretos)**
  - **As informações também podem ser consideradas DP se contiverem características que distinguem uma pessoa natural de outras, como dados biométricos.**
  - **A identificabilidade pode ser clara ou pode depender de uma combinação de atributos que, juntos, permitem identificar uma pessoa.**
    - **Ex: a combinação de "masculino", "52 anos" e "médico" pode ser suficiente para identificar uma pessoa em uma empresa específica, mas não fora dela.**

ABNT NBR ISO/IEC 29100:2024 – Identificadores de DP

Os identificadores de são elementos que podem ser usados para identificar uma pessoa natural.

- **Características Distintivas (identificadores indiretos)**
  - **Exemplos de atributos que podem ser usados para identificar pessoas:**
    - **Idade ou necessidades especiais de vulneráveis**
    - **Alegações de conduta criminosa**
    - **Informação coletada por serviços de saúde**
    - **Conta bancária ou número de cartão de crédito**
    - **Identificador biométrico**
    - **Extratos de cartão de crédito**
    - **Condenações criminais ou delitos cometidos**
    - **Número do cliente**
    - **Data de nascimento**

ABNT NBR ISO/IEC 29100:2024 – Identificadores de DP

Os identificadores de são elementos que podem ser usados para identificar uma pessoa natural.

- **Características Distintivas (identificadores indiretos)**
  - **Exemplos de atributos que podem ser usados para identificar pessoas:**
    - **Perfil financeiro**
    - **Gênero**
    - **Posição ou Trajetória no GPS**
    - **Endereço residencial**
    - **Endereço IP**
    - **Localização fornecida por sistemas de telecomunicação**
    - **Nome**
    - **Identificadores nacionais (ex: número do passaporte)**
    - **Endereço de e-mail pessoal**

ABNT NBR ISO/IEC 29100:2024 – Identificadores de DP

Os identificadores de são elementos que podem ser usados para identificar uma pessoa natural.

- **Metadados**
  - **Fornecem informações descritivas, estruturais e administrativas que ajudam a descrever, localizar, gerenciar e entender um ativo digital, como um documento, imagem ou vídeo.**
  - **Os sistemas de TIC podem eventualmente armazenar DP nos metadados de um ativo digital quando o titular de DP manipula o ativo.**
    - **Ex: O nome do titular de DP pode ser armazenado nos metadados de um documento quando esse titular cria um novo documento ou faz comentários ou altera documentos.**

ABNT NBR ISO/IEC 29100:2024 – Identificadores de DP

Os identificadores de são elementos que podem ser usados para identificar uma pessoa natural.

- **Dados Pessoais Sensíveis**
  - **Categoria de dados cuja natureza é considerada sensível, pois se relacionam à esfera mais íntima do titular de dados pessoais (DP) ou podem ter um impacto significativo sobre ele.**
  - **Exemplos: (Art. 5º , inciso II, da LGPD)**
    - **Dado pessoal sobre origem racial ou étnica, convicção religiosa, opinião política, filiação a sindicato ou a organização de caráter religioso, filosófico ou político, dado referente à saúde ou à vida sexual, dado genético ou biométrico.**

ABNT NBR ISO/IEC 29100:2024 – Salvaguarda de privacidade

Os requisitos de salvaguarda de privacidade são fundamentais para proteção de dados pessoais.

- **1 – Coleta e Retenção de DP:**
  - **As organizações devem estabelecer diretrizes claras sobre como os DP são coletados e por quanto tempo são retidos, garantindo que a coleta seja limitada ao necessário para os fins específicos.**

- **2 – Transferência de DP:**
  - **As regras para a transferência de DP para terceiras partes devem ser bem definidas, incluindo a necessidade de acordos contratuais que garantam a proteção adequada dos dados durante e após a transferência.**

ABNT NBR ISO/IEC 29100:2024 – Salvaguarda de privacidade

Os requisitos de salvaguarda de privacidade são fundamentais para proteção de dados pessoais.

- **3 – Avaliação de Riscos:**
  - **As organizações devem realizar avaliações de riscos para identificar e mitigar potenciais ameaças à privacidade dos titulares de DP, incluindo a análise de como os dados são tratados e as vulnerabilidades associadas.**

- **4 – Implementação de Controles de Privacidade:**
  - **Implementar controles específicos para proteger os DP, que podem incluir medidas organizacionais, técnicas e físicas.**
  - **Esses controles devem ser documentados e revisados periodicamente.**

ABNT NBR ISO/IEC 29100:2024 – Salvaguarda de privacidade

Os requisitos de salvaguarda de privacidade são fundamentais para proteção de dados pessoais.

- **5 – Conformidade Legal:**
  - **As organizações devem estar cientes das legislações aplicáveis e garantir que suas práticas de tratamento de DP estejam em conformidade com as leis de proteção de dados e privacidade.**

- **6 – Políticas de Privacidade:**
  - **A alta direção deve estabelecer e comunicar uma política de privacidade que reflita o compromisso da organização com a proteção dos DP e que seja acessível a todas as partes interessadas.**

ABNT NBR ISO/IEC 29100:2024 – Salvaguarda de privacidade

Os requisitos de salvaguarda de privacidade são fundamentais para proteção de dados pessoais.

- **7 – Monitoramento e Revisão:**
  - **As organizações devem monitorar continuamente os riscos e a eficácia dos controles implementados, realizando análises críticas e ajustes conforme necessário.**

ABNT NBR ISO/IEC 29100:2024 – Política de privacidade

A política estabelece diretrizes e compromissos da organização em relação ao tratamento de DP.

- **1 – Ser Apropriada ao Propósito da Organização:**
  - **A política deve refletir as atividades e os objetivos da organização em relação ao tratamento de DP.**
- **2 – Fornecer Estrutura para Determinação de Objetivos:**
  - **Deve servir como base para definir metas e objetivos relacionados à proteção da privacidade.**
- **3 – Compromisso com Requisitos de Salvaguarda da Privacidade:**
  - **A política deve incluir um compromisso explícito de atender aos requisitos legais e regulamentos aplicáveis à privacidade.**

ABNT NBR ISO/IEC 29100:2024 – Política de privacidade

A política estabelece diretrizes e compromissos da organização em relação ao tratamento de DP.

- **4 – Compromisso com a Melhoria Contínua:**
  - **A política deve promover a melhoria contínua das práticas de privacidade dentro da organização.**
- **5 – Comunicação Interna:**
  - **A política deve ser comunicada a todos os níveis da organização, garantindo que todos os colaboradores estejam cientes das diretrizes e obrigações.**
- **6 – Disponibilidade para Partes Interessadas:**
  - **A política deve estar acessível para as partes interessadas, conforme apropriado, permitindo que os titulares de DP entendam como seus dados são tratados.**

ABNT NBR ISO/IEC 29100:2024 – Princípios de privacidade

Os princípios de privacidade são fundamentais para orientar o tratamento de dados pessoais (DP).

- **1 – Consentimento e escolha:** **(LGPD, Art. 7º, hipóteses para o tratamento de DP)**
  - **Os titulares de DP devem ter a opção de consentir ou não com o tratamento de seus dados, exceto em situações específicas previstas pela legislação.**
- **2 – Legitimidade e especificação de propósito:** **(LGPD, Art. 6º , I – finalidade)**
  - **O tratamento de DP deve ser realizado de forma legítima e para propósitos específicos, que devem ser claramente informados aos titulares.**
- **3 – Limitação de coleta:** **(LGPD, Art. 6º , III – necessidade)**
  - **A coleta de DP deve ser limitada ao que é necessário para os propósitos definidos, evitando a coleta excessiva.**

ABNT NBR ISO/IEC 29100:2024 – Princípios de privacidade

Os princípios de privacidade são fundamentais para orientar o tratamento de dados pessoais (DP).

- **4 – Minimização de dados: (LGPD, Art. 6º , III – necessidade)**
  - **Apenas os dados necessários para o propósito do tratamento devem ser coletados e mantidos.**
- **5 – Uso, retenção e limitação da divulgação: (LGPD, Art. 6º , II – adequação)**
  - **Os DP devem ser utilizados apenas para os fins para os quais foram coletados e não devem ser retidos por mais tempo do que o necessário.**
- **6 – Exatidão e qualidade: (LGPD, Art. 6º , V – qualidade dos dados)**
  - **Os DP devem ser precisos e atualizados, garantindo que a qualidade dos dados seja mantida.**

ABNT NBR ISO/IEC 29100:2024 – Princípios de privacidade

Os princípios de privacidade são fundamentais para orientar o tratamento de dados pessoais (DP).

- **7 – Abertura, transparência e notificação:** **(LGPD, Art. 6º , VI - transparência)**
  - **As organizações devem ser transparentes sobre suas práticas de tratamento de DP e notificar os titulares sobre como seus dados estão sendo utilizados.**
- **8 – Participação individual e acesso:** **(LGPD, Art. 6º , IV – livre acesso)**
  - **Os titulares de DP devem ter o direito de acessar seus dados e participar do processo de tratamento, podendo solicitar correções quando necessário.**
- **9 – Responsabilização:** **(LGPD, Art. 6º , X – responsabilização e prestação de contas)**
  - **As organizações devem ser responsáveis pelo cumprimento dos princípios de privacidade e devem demonstrar conformidade.**

ABNT NBR ISO/IEC 29100:2024 – Princípios de privacidade

Os princípios de privacidade são fundamentais para orientar o tratamento de dados pessoais (DP).

- **10 – Segurança da informação: (LGPD, Art. 6º , VII - segurança)**
  - **Medidas adequadas devem ser implementadas para proteger os DP contra acesso não autorizado, divulgação, alteração ou destruição.**

- **11 – Compliance com a privacidade: (LGPD, Art. 38º , RIPD)**
  - **As organizações devem garantir que suas práticas estejam em conformidade com as leis e regulamentos de privacidade aplicáveis.**

ABNT NBR ISO/IEC 29134:2024 – Privacy Impact Assessment (PIA)

O objetivo é assegurar a elaboração da Avaliação de Impacto à Privacidade (PIA).

- **Fornece uma visão operacional e tática, delineando um processo estruturado com diretrizes para:**
  - **identificar riscos à privacidade dos titulares;**
  - **avaliar impactos reais decorrentes do tratamento de dados;**
  - **analisar adequação de salvaguardas técnicas e organizacionais; e**
  - **documentar decisões e justificar tratamentos de risco.**
- **A norma orienta as organizações a elaborarem uma PIA, por exemplo, quando realizarem a gestão de riscos de privacidade como parte dos requisitos do Sistema de Gestão de Segurança da Informação (SGSI).**

ABNT NBR ISO/IEC 29134:2024 – Privacy Impact Assessment (PIA)

Não confundir a PIA (Privacy Impact Assessment) com a DPIA (Data Protection Impact Assessment).

- **A PIA é um processo amplo e uma boa prática de governança para gerenciar riscos de privacidade, mesmo quando não obrigatório.**

- **A DPIA é um tipo específico de avaliação de impacto, legalmente mandatório e exigido especificamente quando o tratamento de dados pessoais for de alto risco para os direitos e liberdades de indivíduos.**

- **A DPIA é equivale no Brasil ao RIPD (Relatório de Impacto à Proteção de Dados Pessoais).**

ABNT NBR ISO/IEC 29134:2024 – Privacy Impact Assessment (PIA)

Estrutura do Processo de Avaliação de Impacto à Privacidade:

1. **Determinação da necessidade de uma PIA (análise de pertinência).**
   - **Visa determinar se uma PIA deve ser realizada para o contexto do tratamento de dados pessoais.**
2. **Preparação da PIA.**
   - **Visa criar as condições organizacionais e técnicas para a avaliação.**
3. **Execução da PIA**
   - **Visa realizar o processo de avaliação de riscos de privacidade.**
4. **Acompanhamento da PIA**
   - **Visa assegurar a documentação e publicação da PIA, a implementação dos planos de tratamento de riscos de privacidade e a análise crítica e/ou auditoria da PIA.**

Relatório de Impacto à Proteção de Dados Pessoais – RIPD

O Relatório de Impacto à Proteção de Dados Pessoais (RIPD) – Art. 5, inciso XVII, da LGPD.

- **Documentação do controlador que contém a descrição dos processos de tratamento de dados pessoais que podem gerar riscos às liberdades civis e aos direitos fundamentais, bem como medidas, salvaguardas e mecanismos de mitigação de risco**
- **Conforme disposto no art. 38 da LGPD:**
  - **A autoridade nacional poderá determinar ao controlador que elabore relatório de impacto à proteção de dados pessoais, inclusive de dados sensíveis, referente a suas operações de tratamento de dados, nos termos de regulamento, observados os segredos comercial e industrial.**

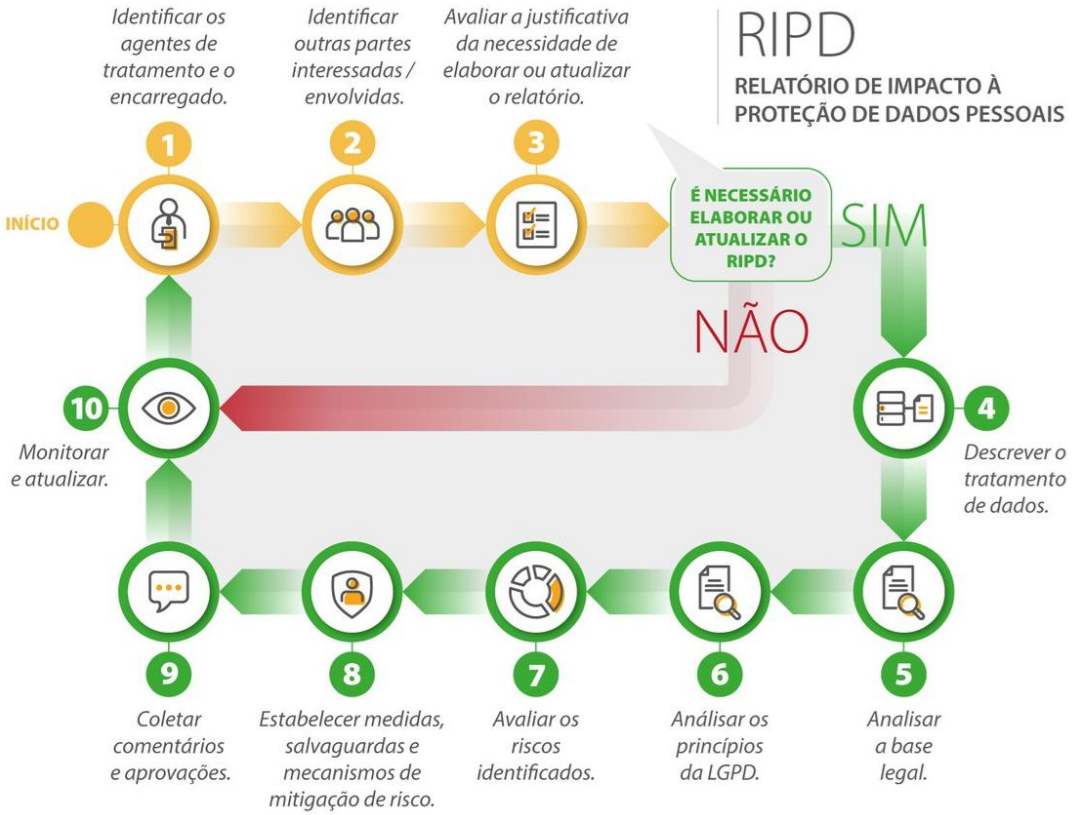
Relatório de Impacto à Proteção de Dados Pressoais – RIPD

Orientação da ANPD – Definição de alto risco – Art. 4 – RES.CD/ANPD Nº 2/2022.

Fonte: ANPD. URL: https://www.gov.br/anpd/pt-br/canais_atendimento/agente-de-tratamento/relatorio-de-impacto-a-protecao-de-dados-pessoais-ripd/relatorio-de-impacto-a-protecao-de-dados-pessoais#p9

Relatório de Impacto à Proteção de Dados Pessoais – RIPD

Orientação da ANPD – Etapas do processo de elaboração do RIPD.



Fonte: ANPD. URL: https://www.gov.br/anpd/pt-br/canais_atendimento/agente-de-tratamento/relatorio-de-impacto-a-protecao-de-dados-pessoais-ripd/relatorio-de-impacto-a-protecao-de-dados-pessoais#p15

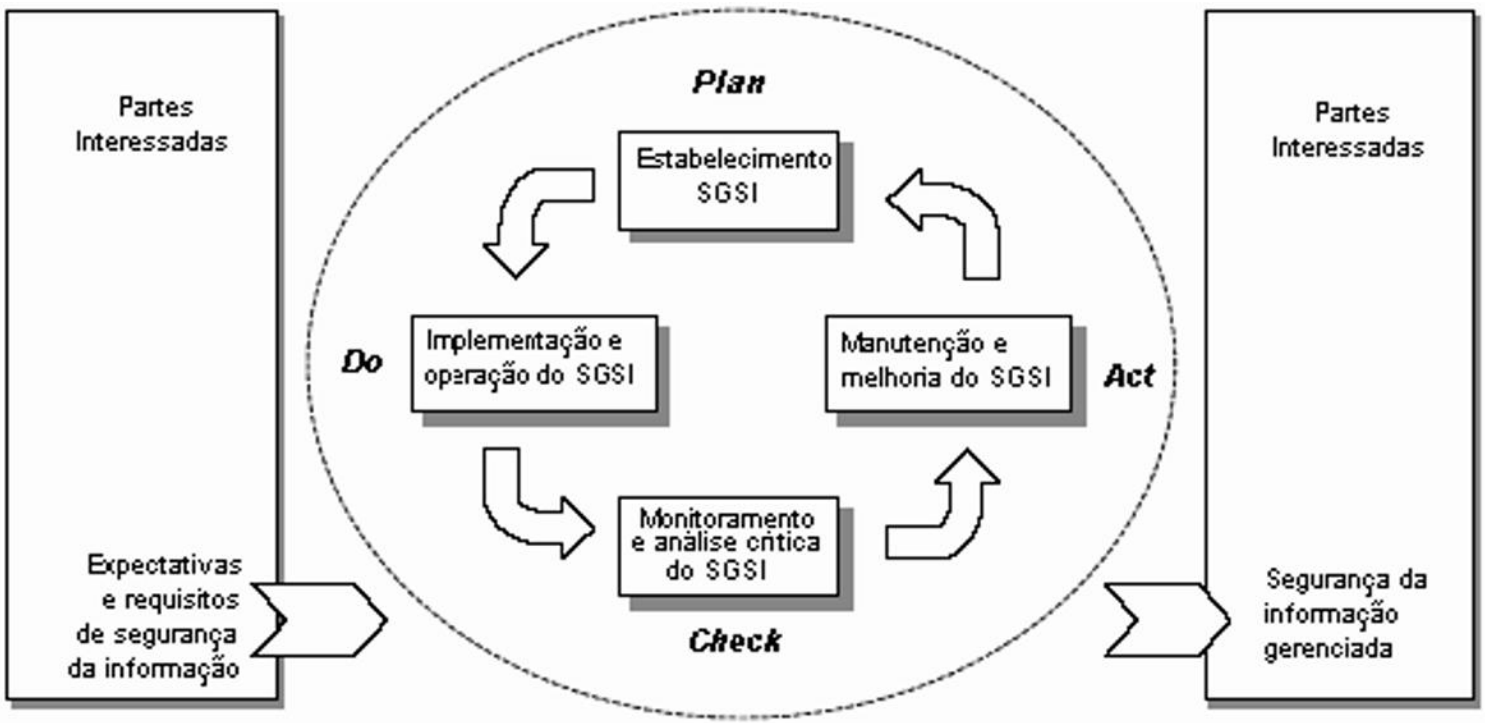
ABNT NBR ISO/IEC 27701 – Sistema de Gestão de Privacidade da Informação (SGPI)

A Gestão de Privacidade da Informação (GPI) visa implantar um processo de gestão sistemática.

- **Os requisitos da ABNT NBR ISO/IEC 27001 mencionando segurança da informação devem ser estendidos para a proteção da privacidade, caso esta seja potencialmente afetada pelo tratamento de DP.**
  - **1 – Assegurar a proteção dos ativos de informação da organização e a proteção dos dados pessoais, garantindo a confidencialidade, a integridade e a disponibilidade desses ativos e a proteção da privacidade.**
  - **2 – Assegurar a conformidade da organização com leis e regulamentos, garantindo a reputação da organização e reduzindo prejuízos financeiros.**

ABNT NBR ISO/IEC 27701 – Sistema de Gestão de Privacidade da Informação (SGPI)

Processo de Implantação: Ciclo Plan-Do-Check-Act (PDCA)



+ Privacidade da Informação

(ABNT NBR ISO/IEC 27001:2006, ABNT, p. vi)

ABNT NBR ISO/IEC 27701 – Sistema de Gestão de Privacidade da Informação (SGPI)

Processo de Implantação: Ciclo Plan-Do-Check-Act (PDCA)

A política, os objetivos, os processos e os procedimentos do SGSI devem ser criados nessa fase, tendo o foco na gestão dos riscos e melhoria da segurança da informação para produzir os resultados almejados.

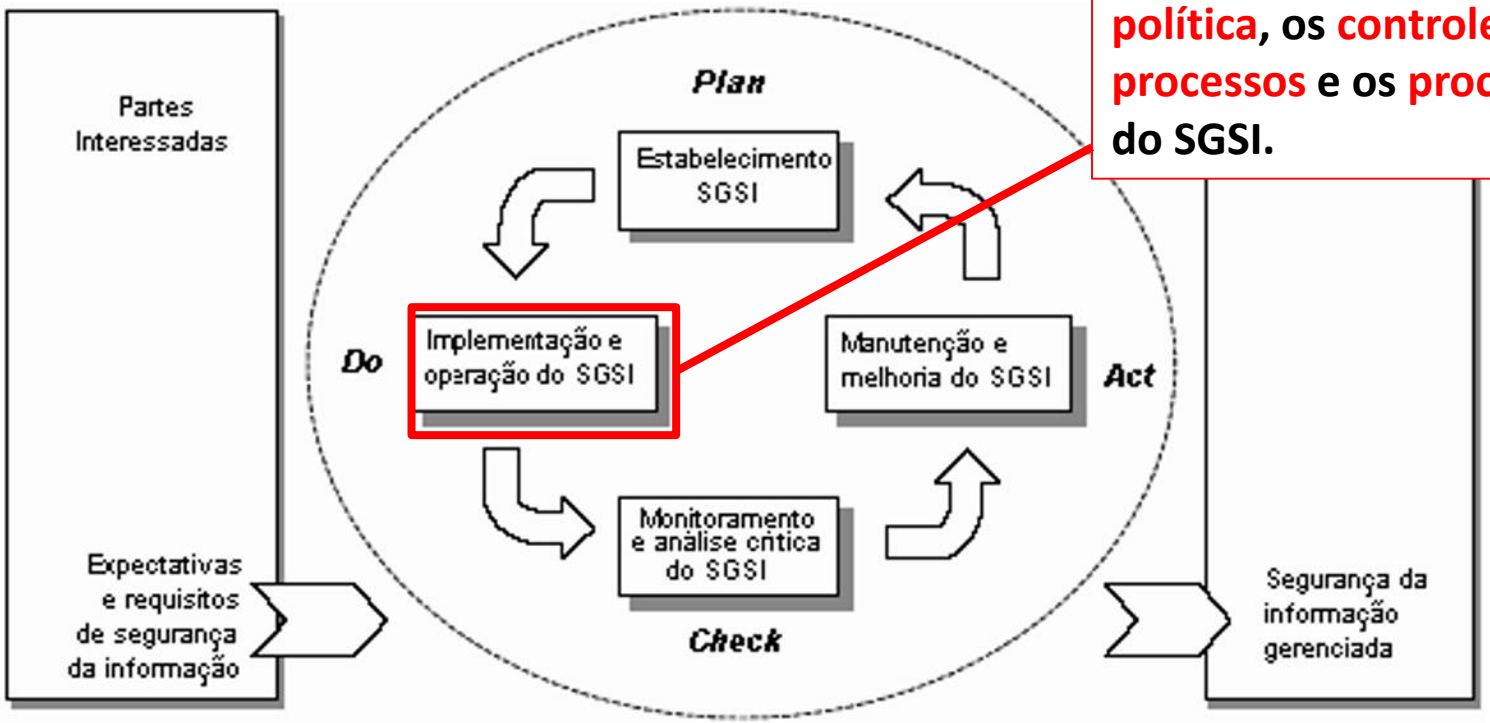
+ Privacidade da Informação

(ABNT NBR ISO/IEC 27001:2006, ABNT, p. vi)

ABNT NBR ISO/IEC 27701 – Sistema de Gestão de Privacidade da Informação (SGPI)

Processo de Implantação: Ciclo Plan-Do-Check-Act (PDCA)

Implementar e operar a política, os controles, os processos e os procedimentos do SGSI.

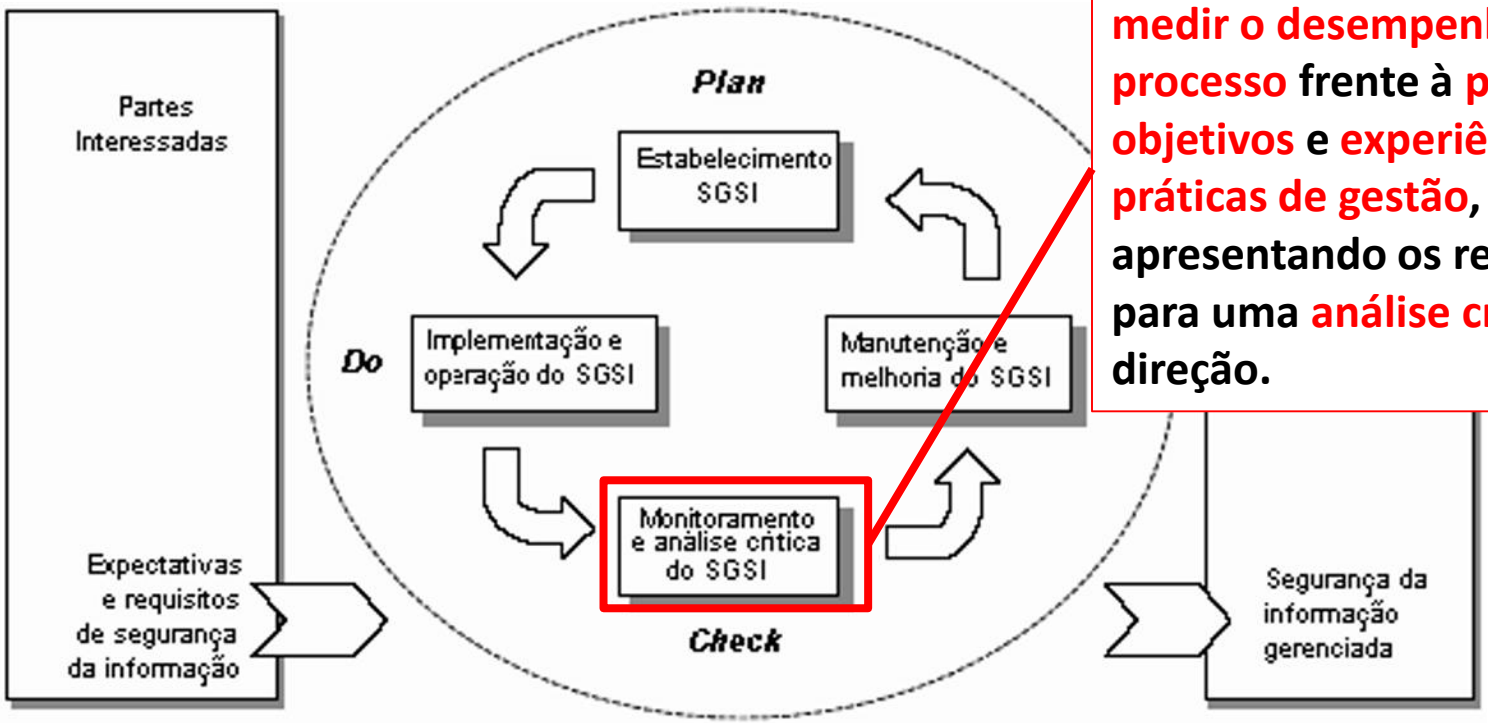


+ Privacidade da Informação

(ABNT NBR ISO/IEC 27001:2006, ABNT, p. vi)

ABNT NBR ISO/IEC 27701 – Sistema de Gestão de Privacidade da Informação (SGPI)

Processo de Implantação: Ciclo Plan-Do-Check-Act (PDCA)



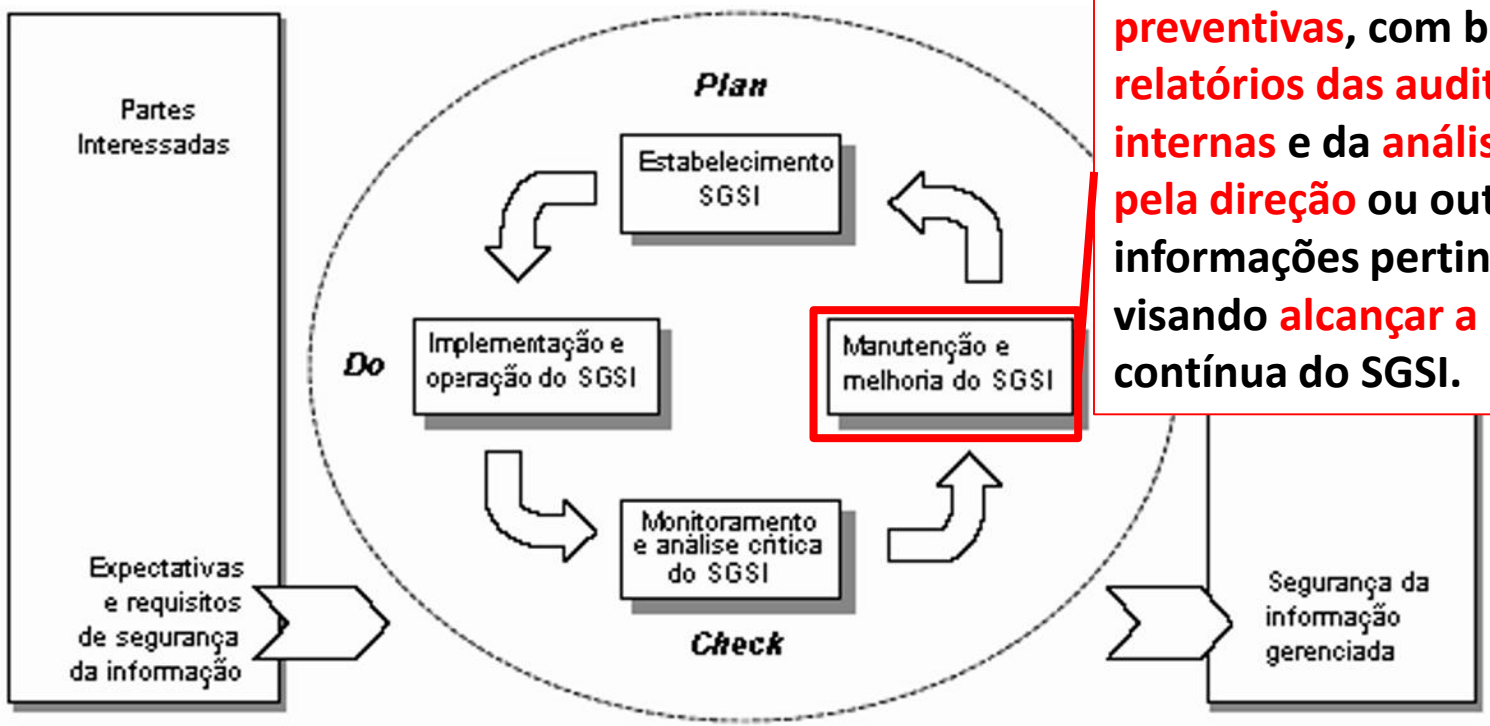
Avaliar e, quando aplicável, medir o desempenho de um processo frente à política, objetivos e experiências práticas de gestão, apresentando os resultados para uma análise crítica pela direção.

+ Privacidade da Informação

(ABNT NBR ISO/IEC 27001:2006, ABNT, p. vi)

ABNT NBR ISO/IEC 27701 – Sistema de Gestão de Privacidade da Informação (SGPI)

Processo de Implantação: Ciclo Plan-Do-Check-Act (PDCA)



Executar as ações corretivas e preventivas, com base nos relatórios das auditorias internas e da análise crítica pela direção ou outras informações pertinentes, visando alcançar a melhoria contínua do SGSI.

+ Privacidade da Informação

(ABNT NBR ISO/IEC 27001:2006, ABNT, p. vi)

ABNT NBR ISO/IEC 27002 – Controles de Segurança da Informação (Estendido – 27701)

Domínios de Segurança dos Controles da Norma:

- **Políticas de Segurança da Informação**
  - **+ Política de Privacidade (política interna).**
  - **+ Aviso de Privacidade (política externa).**
  - **+ Conformidade com as leis e regulamentações para o tratamento de DP.**
- **Organização da Segurança da Informação**
  - **+ Nomeação do Encarregado de Dados Pessoais (DPO).**
  - **+ Nomeação de um Comitê de Gestão de Privacidade.**
  - **+ Política para uso de dispositivo móvel com DP.**
- **Segurança em Recursos Humanos**
  - **+ Conscientização, educação e treinamento abordando as consequências da violação de privacidade ou de regras de segurança e procedimentos para a organização, seus membros e o titular de DP.**

ABNT NBR ISO/IEC 27002 – Controles de Segurança da Informação (Estendido – 27701)

Domínios de Segurança dos Controles da Norma:

- **Gestão de Ativos**
  - **+ Incluir DP como uma das categorias de classificação de informação.**
  - **+ Conscientização sobre a definição de DP e como reconhecer DP.**
  - **+ Gerenciamento de mídias removíveis com DP:**
    - **Controle de transferência, armazenamento seguro e descarte.**

- **Controle de Acesso**
  - **+ Registro e cancelamento de usuários que administrem ou operem sistemas e serviços que tratam DP.**
  - **+ Registro preciso e atualizado dos perfis dos usuários criados em sistemas de informação que manipulam DP.**
  - **+ Procedimentos seguros de entrada para quaisquer contas de usuários sob o controle do cliente.**

ABNT NBR ISO/IEC 27002 – Controles de Segurança da Informação (Estendido – 27701)

Domínios de Segurança dos Controles da Norma:

- **Criptografia**
  - **+ Política para o uso de controles criptográficos para proteger DP sensíveis.**
- **Segurança Física e do Ambiente**
  - **+ Reutilização ou descarte seguro de equipamentos com DP.**
  - **+ Restringir a criação de material físico que inclua DP ao mínimo necessário.**
- **Segurança nas Operações**
  - **+ Requisitos para cópia de segurança, recuperação e restauração de DP.**
  - **+ Registros de eventos (logs) que gravem o acesso ao DP (por quem, quando, qual titular de DP e quais mudanças).**
  - **+ Critério em relação a quando e como as informações de log podem se tornar disponíveis ou usáveis pelo cliente.**
  - **+ Proteção das informações dos registros de eventos (logs) com DP.**

ABNT NBR ISO/IEC 27002 – Controles de Segurança da Informação (Estendido – 27701)

Domínios de Segurança dos Controles da Norma:

- **Segurança nas Comunicações**
  - **+ Assegurar que regras relativas ao tratamento de DP são mandatórias por todo o sistema e fora dele em transferências de informações.**
  - **+ Assegurar que os indivíduos que operam com acesso aos DP estejam sujeitos a um acordo obrigatório de confidencialidade.**
- **Aquisição, Desenvolvimento e Manutenção de Sistemas**
  - **+ Assegurar que os DP transmitidos por redes não confiáveis estejam criptografados para a transmissão.**
  - **+ Políticas para o projeto e desenvolvimento de sistemas incluam diretrizes para as necessidades de tratamento de DP da organização.**
  - **+ Projeto de sistemas e/ou componentes que tratam DP com os princípios de *privacy by design* e *privacy by default*, incluindo sistemas terceirizados.**
  - **+ Não usar DP para propósitos de teste. Usar DP falso ou sintético.**

ABNT NBR ISO/IEC 27002 – Controles de Segurança da Informação (Estendido – 27701)

Domínios de Segurança dos Controles da Norma:

- **Relacionamento na Cadeia de Suprimento**
  - **+ Especificar as medidas mínimas técnicas e organizacionais que o fornecedor precisa atender nos acordos que tratam DP para que a organização cumpra com as suas as obrigações de proteção de DP e segurança da informação.**

- **Gestão de Incidentes de Segurança da Informação**
  - **+ Estabelecer as responsabilidades e procedimentos para a identificação e registro de violações de DP.**
  - **+ Resposta aos incidentes de segurança da informação com violação de DP devem ser tratadas e notificadas aos titulares de DP e autoridade de supervisão.**
  - **+ Incluir cláusulas que cobrem a notificação de uma violação envolvendo DP nos contratos com os operadores de DP.**

ABNT NBR ISO/IEC 27002 – Controles de Segurança da Informação (Estendido – 27701)

Domínios de Segurança dos Controles da Norma:

- **Gestão da Continuidade do Negócio**
  - **Sem especificação de novos controles.**

- **Conformidade**
  - **+ Identificar quaisquer sanções legais potenciais relativas ao tratamento de DP, incluindo multas substanciais oriundas diretamente da autoridade de supervisão local.**
  - **+ Reter cópias de seus procedimentos e políticas de privacidade associados, por um período conforme especificado na sua programação de retenção.**
  - **+ Prover evidências independentes de que a segurança da informação está implementada e é operada de acordo com os procedimentos e as políticas da organização (principalmente no caso de um operador de DP).**
  - **+ Incluir métodos de análise crítica das ferramentas e componentes relacionados ao tratamento de DP.**

ABNT NBR ISO/IEC 27701 – Controles Adicionais para Controladores de DP

Controles adicionados pela ABNT NBR ISO/IEC 27701 para Controladores de DP:

- **Condições para coleta e tratamento**
  - **Determinar e documentar que o tratamento é lícito, com bases legais conforme as jurisdições aplicáveis, e com propósitos legítimos e claramente estabelecidos.**
    - **Identificação e documentação do propósito**
    - **Identificação de bases legais**
    - **Determinando quando e como o consentimento deve ser obtido**
    - **Obtendo e registrando o consentimento**
    - **Avaliação de impacto de privacidade**
    - **Contratos com operadores de DP**
    - **Controlador conjunto de DP**
    - **Registros relativos ao tratamento de DP**

ABNT NBR ISO/IEC 27701 – Controles Adicionais para Controladores de DP

Controles adicionados pela ABNT NBR ISO/IEC 27701 para Controladores de DP:

- **Obrigações para com os titulares de DP**
  - **Para assegurar que os titulares de DP sejam providos com informações apropriadas sobre o tratamento de seus DP e para atender quaisquer outras obrigações aplicáveis aos titulares de DP, relativas ao tratamento dos seus DP.**
  - **Determinando e cumprindo as obrigações para com os titulares de DP**
  - **Determinando as informações para os titulares de DP**
  - **Fornecendo informações aos titulares de DP**
  - **Fornecendo mecanismos para modificar ou cancelar o consentimento**
  - **Fornecendo mecanismos para negar o consentimento ao tratamento de DP**
  - **Acesso, correção e/ou exclusão**
  - **Obrigações dos controladores de DP para informar aos terceiros**
  - **Fornecendo cópia dos DP tratados**
    - **Tratamento de solicitações**
    - **Tomada de decisão automatizada**

ABNT NBR ISO/IEC 27701 – Controles Adicionais para Controladores de DP

Controles adicionados pela ABNT NBR ISO/IEC 27701 para Controladores de DP:

- **Privacy by design e Privacy by Default**
  - **Assegurar que processos e sistemas sejam projetados de tal forma que a coleta e o tratamento (incluindo o uso, divulgação, retenção, transmissão e descarte) estejam limitados ao que é necessário para o propósito identificado.**
    - **Limite de coleta**
    - **Limite de tratamento**
    - **Precisão e qualidade**
    - **Objetivos de minimização de DP**
    - **Desidentificação e exclusão de DP ao final do tratamento**
    - **Arquivos temporários**
    - **Retenção**
    - **Descarte**
    - **Controles de transmissão de DP**

ABNT NBR ISO/IEC 27701 – Controles Adicionais para Controladores de DP

Controles adicionados pela ABNT NBR ISO/IEC 27701 para Controladores de DP:

- **Compartilhamento, transferência e divulgação de DP**
  - **Determinar se e documentar quando o DP é compartilhado, transferido para outras jurisdições ou terceiros e/ou divulgado de acordo com as obrigações aplicáveis.**
    - **Identificação das bases para a transferência de DP entre jurisdições**
    - **Países e organizações internacionais para os quais DP podem ser transferidos**
    - **Registros de transferência de DP**
    - **Registros de divulgação de DP a terceiros**

ABNT NBR ISO/IEC 27701 – Controles Adicionais para Operadores de DP

Controles adicionados pela ABNT NBR ISO/IEC 27701 para Operadores de DP:

- **Condições para coleta e tratamento**
  - **Documentar e determinar que o tratamento é lícito, com base legal, conforme as jurisdições aplicáveis e com propósitos legítimos e claramente definidos.**
    - **Acordo com o cliente**
    - **Propósitos da organização**
    - **Uso para marketing e propaganda**
    - **Instruções infratoras**
    - **Obrigações do cliente**
    - **Registros relativos ao tratamento de DP**

ABNT NBR ISO/IEC 27701 – Controles Adicionais para Operadores de DP

Controles adicionados pela ABNT NBR ISO/IEC 27701 para Operadores de DP:

- **Obrigações para com os titulares de DP**
  - **Assegurar que os titulares de DP sejam providos com informações apropriadas sobre o tratamento de seus DP, e que estejam de acordo com quaisquer outras obrigações aplicáveis para os titulares de DP relativas ao tratamento de seus DP.**
    - **Compliance com obrigações para com os titulares de DP**
      - **Ex: Incluir a correção ou exclusão dos DP em um tempo hábil.**

ABNT NBR ISO/IEC 27701 – Controles Adicionais para Operadores de DP

Controles adicionados pela ABNT NBR ISO/IEC 27701 para Operadores de DP:

- **Privacy by design e Privacy by Default**
  - **Assegurar que processos e sistemas sejam projetados de forma que a coleta e o tratamento de DP (incluindo o uso, divulgação, retenção, transmissão e descarte) estejam limitados ao que é necessário para o propósito identificado.**
    - **Arquivos temporários**
    - **Devolução, transferência ou descarte de DP**
    - **Controles de transmissão de DP**

ABNT NBR ISO/IEC 27701 – Controles Adicionais para Operadores de DP

Controles adicionados pela ABNT NBR ISO/IEC 27701 para Operadores de DP:

- **Compartilhamento, transferência e descarte de DP**
  - **Determinar se e documentar quando DP são compartilhados, transferidos para outras jurisdições ou terceiros e/ou divulgados, de acordo com as obrigações aplicáveis.**
    - **Fundamentação para a transferência de DP entre jurisdições**
    - **Países e organizações internacionais para os quais o DP podem ser transferidos**
    - **Registros de DP divulgados para terceiros**
    - **Notificação de solicitações de divulgação de DP**
    - **Divulgações legalmente obrigatórias de DP**
    - **Divulgação de subcontratados usados para tratar DP**
    - **Contratação de um subcontratado para tratar DP**
    - **Troca de subcontratado para tratar DP**

Gestão da Privacidade dos Dados Pessoais

Pós-graduação em Compliance de Cibersegurança

linkedin.com/in/anderson-oliveira-da-silva-58221680

Obrigado!

Prof. Anderson Oliveira da Silva

Gestor de Segurança da Informação
Encarregado de Dados Pessoais
anderson@inf.puc-rio.br

DEPARTAMENTO DE INFORMÁTICA PUC·RIO

PUC RIO